

Incident Response Report (Client-Ready Version)

Incident Overview

On 30 March 2026, a ransomware incident was identified after an employee reported that files on a contractor workstation had been encrypted. An investigation confirmed that the incident was caused by Pay2Key ransomware.

The attacker initially gained access to the organisation's network on 28 February 2026 by exploiting a remote access service (Remote Desktop Protocol, or RDP) that was exposed directly to the internet. This service was not protected by multi-factor authentication (MFA) and had no account lockout controls, allowing the attacker to guess login credentials.

Once inside the network, the attacker remained undetected for approximately 30 days. During this time, they: - Collected passwords from systems - Explored the network to identify additional devices - Installed remote access software to maintain control

On 30 March 2026, the attacker deployed ransomware, encrypting 763 files on a contractor workstation within minutes. They also disabled system recovery features to prevent restoration.

Key Findings (Non-Technical Summary)

- The attacker accessed the network through an exposed remote access service
- They had undetected access for 30 days
- Security alerts were generated but not reviewed or acted upon
- Two systems were compromised
- All passwords in the environment should be considered exposed
- The attack was preventable with basic security controls

Scope of Impact

Two systems were confirmed compromised:

- Domain Controller: Used to access and control the network and collect passwords
- Contractor Workstation: Used to deploy ransomware and encrypt files

Five additional systems showed no evidence of compromise.

Impact Summary

- Systems affected: 2 out of 7
- Files encrypted: 763
- Credentials: All potentially compromised
- Business impact: Contractor workstation unusable
- Risk of recurrence: High if issues are not addressed

How the Attack Happened

Initial Access

The attacker gained access by repeatedly attempting to log in through an exposed remote access service until they successfully guessed the administrator password.

Establishing Control

After gaining access, the attacker: - Extracted passwords from memory - Installed remote access software for continued access - Explored the network to identify other systems

Preparing for Ransomware

The attacker then: - Disabled backup and recovery features - Installed malicious software that corrupted system files - Ensured they could maintain access even if interrupted

Ransomware Deployment

On 30 March 2026, the attacker deployed ransomware, which: - Encrypted files within minutes - Displayed a ransom note to the user - Removed evidence of the ransomware file after execution

Root Cause

The incident was caused by a combination of security weaknesses:

- Remote access (RDP) was exposed directly to the internet
 - No multi-factor authentication was in place
 - No account lockout policy to prevent repeated login attempts
 - Security alerts were not monitored or acted upon
 - No restrictions between systems, allowing the attacker to move freely
-

Detection and Response Gaps

Security tools in place detected suspicious activity at multiple stages of the attack. However, these alerts were not reviewed or acted upon.

If any of these alerts had been investigated, the attack could have been stopped before the ransomware was deployed.

Data Exposure Assessment

No evidence of data being stolen was identified. However, some types of activity (such as file transfers through remote access sessions) may not have been visible in the available data.

This means data theft cannot be completely ruled out.

Risk Assessment

Key risks identified:

1. Repeat attack using the same remote access method
2. Continued access using stolen passwords
3. Possible undetected data theft
4. Long-term hidden access using advanced techniques

Overall risk remains high until remediation actions are completed.

Recommendations

Immediate Actions

1. Disable internet-facing remote access (RDP)
2. Isolate affected systems
3. Reset all passwords across the environment
4. Rebuild compromised systems from clean backups
5. Remove unauthorized remote access software

Short-Term Actions

1. Review and respond to all security alerts
2. Check for additional unauthorized access
3. Restore systems from backups created before the attack

Long-Term Improvements

1. Implement multi-factor authentication for all remote access
 2. Introduce account lockout policies
 3. Establish a process for monitoring and responding to alerts
 4. Restrict access between systems to limit attacker movement
 5. Use named administrator accounts instead of shared accounts
-

Recovery Plan Summary

- Rebuild affected systems
 - Reset all credentials
 - Secure remote access before restoring services
 - Monitor systems closely for at least 72 hours after recovery
-

Conclusion

This incident was the result of preventable security gaps. While the organisation had tools capable of detecting the attack, the lack of monitoring and response allowed the attacker to remain undetected for an extended period.

By addressing the identified weaknesses and implementing the recommended controls, the organisation can significantly reduce the risk of future incidents.

Note on Technical Details

Detailed technical analysis, including logs, malware behaviour, and detection rules, has been retained in appendices for use by technical teams. This main report focuses on clarity and decision-making for business stakeholders.